Module 1 — Hunt the Front Door by Hand (30 min, together)

> We do this together. Type along if you're hands-on; watch the screen if not. **Level coverage: L0 → L1.** You leave with two hunts on disk: **H-0004** (done) and **H-0005** (open).

Setup (5 min)

1. Install ATHF. In a terminal, run this block. It throws away any old venv so everyone is on the same build:

```
deactivate 2>/dev/null
rm -rf .venv
python3 -m venv .venv
source .venv/bin/activate
pip install --upgrade pip
pip install 'agentic-threat-hunting-framework[all]'
athf --version
```

You want a version number back from the last line. No version? Flag one of us. No LLM key needed today.

2. Log in to Splunk. Open the credentials sheet, type your name in one free row (one person per row), and open that row's **Splunk URL** in your browser. Log in with that row's username and password, then go to **Search & Reporting**. All the data lives in `index=thrunt`.

3. Set the time picker to Last 30 days. The time picker is the drop-down to the right of the search bar. The attack happened over the past week, so "Last 24 hours" misses most of it — and "Last 7 days" cuts off the very start.

4. Set up your ATHF workspace. In the same terminal:

```
athf init
```

`athf init` asks five quick questions (workspace name, SIEM, EDR, hunt-ID prefix, retention). **Just press Enter through all of them.** The defaults (Splunk, `H-`, and so on) are exactly what this workshop expects. This creates `hunts/`, `AGENTS.md`, and the hunt template. Confirm it worked:

```
athf hunt list
```

Three seeded example hunts (H-0001–H-0003) is expected. Leave them.

If `athf` isn't found, activate the venv from step 1 (`source .venv/bin/activate`), then `athf --version`.

Part A — Follow the process tree (12 min)

Guiding question (orientation): *The alert says `node.exe` ran right after a package install on `WS-BUILD-01`. Before you search: what would a malicious install do that a normal one wouldn't?*

How lineage works in eCAR. Every process event carries four fields at the top level:

- `pid` is the process itself. `ppid` is the process that launched it (its parent's `pid`).

- `hostname` is where it ran. `principal` is the account it ran as.

So a process's **children** are `ppid=<its pid>`, and its **siblings** share its `ppid`. One catch: Windows reuses PIDs. A PID names one process on one host, and only while that process lives. So every PID search below also says `hostname="WS-BUILD-01"`, and you glance at `_time`.

How you read the results. For A1 and A2, stay in Splunk's default **Events** view and read the event itself: that's what an eCAR record looks like, and it shows you where `pid` and `ppid` sit. From A3 on, the search ends in `| table`, so the rows line up as a timeline with `_time` first.

Moving a PID to the next search. PIDs are short numbers. Write them down and type them over the `<...>` placeholder in the next search.

A1. Start at the alert.

Why this pivot: The alert names node running a post-install script on WS-BUILD-01. Find that process and see who launched it.

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" properties.command_line="*postinstall.js*"
```

Read the event. It's one JSON record: `hostname`, `principal`, `pid` and `ppid` at the top, and the process details under `properties` (`command_line`, `image_path`, `parent_image_path`). You'll also see two long UUID fields; we don't use them. Write down two numbers, labelled: **node's pid** and **node's ppid**.

A2. What did node launch?

Why this pivot: Follow the children: processes on this host whose `ppid` is node's `pid`.

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" ppid=<node's pid>
```

Still the Events view. Check that this event's `ppid` is the number you wrote down.

A3. Every shell on this host, in time order.

Why this pivot: A child that goes nowhere isn't the end. Widen out to every `cmd.exe` on WS-BUILD-01. The last filter keeps the shells that mention `telemetry`, the word in A2's shell. From here on the results are a table.

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" properties.image_path="*\\cmd.exe"
properties.command_line="*telemetry*"
| sort _time
| table _time pid ppid properties.parent_image_path principal
  properties.image_path properties.command_line
```

Compare each row's `ppid` with your A1 numbers; `properties.parent_image_path` names the parent. Which shell did node launch, and which one did node's parent launch?

A4. What did that shell run?

Why this pivot: Commands tell you intent. Follow the `/k` shell's children: its `pid` from A3 goes in as the `ppid`.

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" ppid=<the /k shell's pid>
| sort _time
| table _time pid ppid properties.parent_image_path principal
  properties.image_path properties.command_line
```

Guiding question (interpretation): *You have a chain of four searches. What's the one-sentence story, and why does it matter that the package is signed with a clean hash?*

Part B — Count the cost (3 min)

Guiding question (reflection): *How many searches did that take? How many PIDs did you write down and retype, how many tabs are open, how many notes did you scribble? And where is any of it written down right now?*

Count them out loud. Then look at where the answer lives: your browser history and your head. Close the laptop and the hunt is gone.

Part C — Write it down (10 min)

Guiding question (decision): *You found one whole chain. You're about to find a loose thread. Which hunt is `completed` and which stays `in-progress`, and why is writing down the open one just as important?*

H-0004 — the post-install execution chain

Six steps, one slide each.

1. Create the hunt. Copy the whole command and put your name in `--hunter`.

```
athf hunt new \
  --title "Trojanized build-CLI post-install spawns shell + recon" \
  --technique T1195.002 \
  --tactic execution --tactic initial-access \
  --platform windows \
  --data-source edr \
  --actor "CRON GOBLIN" \
  --behavior "package-manager post-install script is followed by an interactive shell that runs host/domain recon" \
  --location "developer workstations (WS-BUILD-*, WS-DEV-*)" \
  --evidence "eCAR process create, linked by pid/ppid on one host: node postinstall.js, then a sibling cmd.exe /k shell running whoami/net/ipconfig" \
  --threat-context "packmule-cli@2.4.1 backdoored via compromised publish token; signed binary, clean hash, no CVE" \
  --hunter "<your-name>" \
  --non-interactive
```

2. Open the file. ATHF names it with the next free number (**H-0004** in a fresh workspace, after the three examples) and prints the path: `hunts/production/2026/Q4/H-0004.md`. Open that file in your editor. The **ABLE Scoping** table under LEARN is already filled from your flags.

> **Tip (macOS):** `open -t hunts/production/2026/Q4/H-0004.md` pops the file straight into your text editor from the terminal.

> **If you're ahead:** ATHF's template puts the *Hypothesis Statement* under **LEARN**, and calls **OBSERVE** *Expected Behaviors*. Type the hypothesis: *CRON GOBLIN uses a post-install script to open a recon shell on*

> *dev workstations*. Under **OBSERVE** → *What Suspicious Looks Like*, type: *a post-install script, then an interactive `/k` shell from the same parent running recon*.

3. Paste CHECK. Two blocks, both under **CHECK → Hunting Queries**.

H-0004 CHECK, queries. Paste over `[Your initial query]` and its fences.

```
~~~spl
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" properties.command_line="*postinstall.js*"

index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" ppid=5648

index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" properties.image_path="*\\cmd.exe"
properties.command_line="*telemetry*"
| sort _time
| table _time pid ppid properties.parent_image_path principal
  properties.image_path properties.command_line

index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
hostname="WS-BUILD-01" ppid=5668
| sort _time
| table _time pid ppid properties.parent_image_path principal
  properties.image_path properties.command_line
~~~
```

H-0004 CHECK, notes. Select the `**Query Notes:**` line and its two placeholder bullets, and paste this over them.

```
**Query Notes:**
- A1: node postinstall.js as alice.chmod. pid 5648, ppid 5612 (PowerShell).
- A2: node's only child: cmd.exe /c "packmule --activate-telemetry". Dead end.
- A3: cmd.exe /k "packmule telemetry shell", pid 5668, ppid 5612: node's sibling.
- A4: the /k shell ran whoami /all, net group "Domain Admins" /domain, ipconfig /all.
```

4. Paste KEEP. Two blocks, both under **KEEP**.

H-0004 KEEP. Select from the `[Concise summary…]` line down to the second example row of the **Findings** table (the `suspected` one), and paste this over it. The evidence-gate line under the table stays.

```
**Suspected.** Initial access + execution on WS-BUILD-01 (alice.chmod).

### Findings

Things you're reporting as malicious. Only `confirmed` and `suspected` belong here.

| **Verdict** | **Subject** | **Ticket** | **Evidence** | **Independent Confirmation** |
|-------------|-------------|------------|--------------|------------------------------|
| `suspected` | WS-BUILD-01 · alice.chmod | N/A | postinstall → /k shell → recon | None — telemetry only |
```

H-0004 FOLLOW-UP. Under **Follow-up Actions**, replace the two example lines with:

```
- [ ] Outbound C2 from WS-BUILD-01 → H-0005
```

5. Set status and verdict. Change `planning` to `completed` in two places: the `status:` line at the top of the file and the `- **Status:**` line under Hunt Metadata. The verdict, `suspected`, came in with the KEEP block.

> **On "verdict":** each **Findings** row has one. Read the line under the table: `confirmed` needs proof from outside the logs (host forensics, a reproduction). Logs alone are `suspected`, and that's all we have today. **Status** is separate: it says whether you're done hunting (`planning` → `in-progress` → `completed`).

6. Validate.

```
athf hunt validate H-0004
```

Expect ✅ `Hunt is valid!`

H-0005 — where did it call home?

Endpoint logs show only the proxy (kickoff slide: *How traffic leaves*). So you get the real destination in three hops: **host → proxy → domain**.

C1. Where did node connect to?

Why this pivot: Find the network connections node opened on this host, which process opened them (`pid`), and this host's own IP.

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=FLOW
hostname="WS-BUILD-01" properties.direction=OUTBOUND properties.image_path="*node*"
| stats count by pid properties.src_ip properties.dst_ip properties.dst_port
```

`properties.direction=OUTBOUND` keeps only the connections this host started. Without it, servers log *inbound* flows from the same IP, so one IP looks like many hosts.

Compare the `pid` with node's pid from A1. Then write down two values: `src_ip` is **WS-BUILD-01's IP**, and `dst_ip:dst_port` is where node went.

C2. What did the proxy connect to for this host?

Why this pivot: The proxy logs the client IP and the destination. Search for WS-BUILD-01's IP from C1. `http_method=CONNECT` keeps only HTTPS tunnels (what a script like node opens) and drops the inspected browser traffic. Next to each destination you also get `url_category` (the proxy's label for the site), `user` (the login the proxy saw) and `bytes_out`.

```
index=thrunt sourcetype="apache:access:json" client="<the IP from C1>"
http_method=CONNECT
| stats count, sum(bytes_out) AS bytes_out by server, url_category, user
| sort - count
```

Which of these names don't you recognize? Compare its category and user with the well-known name above it, and add up its rows against C1's count.

C3. Is it regular?

Why this pivot: Malware calls home on a timer. People don't.

```
index=thrunt sourcetype="apache:access:json" client="<the IP from C1>"
server="<the name you didn't know>"
| timechart span=5m count
```

Now record it as **H-0005**, the same six steps as H-0004.

1. Create the hunt. Copy the whole command and put your name in `--hunter`.

```
athf hunt new \
  --title "Periodic outbound to CDN-lookalike after build-CLI install" \
  --technique T1071.001 \
  --tactic command-and-control \
  --platform windows \
  --data-source proxy \
  --actor "CRON GOBLIN" \
  --behavior "regular-interval HTTPS to a young CDN-lookalike domain following post-install execution" \
  --location "WS-BUILD-01 egress via PROXY-01" \
  --evidence "eCAR FLOW to the proxy, then proxy access log: ~5-min-interval CONNECTs to cdn-packmule-telemetry.net" \
  --hunter "<your-name>" \
  --non-interactive
```

2. Open the file: `hunts/production/2026/Q4/H-0005.md`, next to H-0004 (macOS: `open -t hunts/production/2026/Q4/H-0005.md`).

3. Paste CHECK. Same two placeholders as H-0004.

H-0005 CHECK, queries. Paste over `[Your initial query]` and its fences.

~~~~
~~~spl
index=thrunt sourcetype="evidenceforge:ecar:json" object=FLOW
hostname="WS-BUILD-01" properties.direction=OUTBOUND properties.image_path="*node*"
| stats count by pid properties.src_ip properties.dst_ip properties.dst_port

index=thrunt sourcetype="apache:access:json" client="10.60.10.11" http_method=CONNECT
| stats count, sum(bytes_out) AS bytes_out by server, url_category, user
| sort - count

index=thrunt sourcetype="apache:access:json" client="10.60.10.11"
server="cdn-packmule-telemetry.net"
| timechart span=5m count
~~~
~~~~

H-0005 CHECK, notes. Select the `**Query Notes:**` line and its two bullets, and paste this over them.

```
**Query Notes:**
- C1: pid 5996 (a later node), 10.60.10.11 → 10.60.20.30:3128 (PROXY-01), 121 flows.
- C2: cdn-packmule-telemetry.net, "Software/Updates" as alice: 103 + 18 blocked = 121.
- C3: steady 0–2 per 5-min bucket for ~10h, never a long gap.
```

4. Paste KEEP. Same selections as H-0004.

H-0005 KEEP. Select from `[Concise summary…]` down to the `suspected` example row, and paste this over it.

```
**Suspected, still open.** ~5-min beacon to cdn-packmule-telemetry.net via PROXY-01.

### Findings

Things you're reporting as malicious. Only `confirmed` and `suspected` belong here.

| **Verdict** | **Subject** | **Ticket** | **Evidence** | **Independent Confirmation** |
|-------------|-------------|------------|--------------|------------------------------|
| `suspected` | WS-BUILD-01 · 10.60.10.11 | N/A | ~5-min CONNECTs, ~10h | None — telemetry only |
```

H-0005 FOLLOW-UP. Replace the two example lines under **Follow-up Actions**:

```
- [ ] Who else talks to it? Real CDN?
```

5. Set status and verdict. Change `planning` to `in-progress` in both status lines: the hunt stays open. The verdict stays `suspected` (logs only); the follow-up line is where "needs follow-up" lives.

6. Validate.

```
athf hunt validate H-0005
```

Expect ✅ `Hunt is valid!`

Stop here — you should see

```
athf hunt list
```

H-0004 and H-0005, plus the 3 examples. Widen your terminal if the ID column shows `H…`.

```
athf hunt validate
```

Every hunt passes.

Fell behind? Copy the two `athf hunt new` commands above, then the paste blocks, and you're caught up.

Next: that was one host and four hops, and it only survives because you wrote it down. In Module 2 you search those notes to find a victim you had no indicator for.